Compte-rendu de TP — Kit du Bastion

Étudiante : Rayanatou
Tâches attribuées : Lundi, Mardi et Jeudi

Poste audité : `diallo-Laptop-12-13th-Gen-Intel-Core`
Score final : 100 / 100 — VALIDÉ

1. LUNDI : LE BASTION (OPTIONS 1 ET 2)

Pour commencer le TP, j'ai réalisé l'audit général de mon ordinateur portable sous Ubuntu afin de vérifier son niveau de sécurité de base. Avec l'option 1 (*Bilan du bastion*), j'ai contrôlé que le système était bien à jour, que le disque était protégé et qu'il n'y avait pas de faille évidente de configuration.

Ensuite, avec l'option 2 (*Comptes et droits*), j'ai vérifié la liste des comptes utilisateurs présents sur la machine ainsi que les droits d'administration (`sudo`). Cela m'a permis de m'assurer qu'il n'existait aucun compte oublié, aucun compte sans mot de passe et que les fichiers sensibles du système étaient bien protégés.

2. MARDI : LES REMPARTS (OPTIONS 3 ET 4)

Le deuxième volet consistait à analyser l'exposition réseau de ma machine et à vérifier l'historique des connexions. Avec l'option 3 (*Qui écoute ?*), j'ai analysé les ports ouverts sur mon PC. Le bilan est rassurant : **aucun port TCP n'est ouvert vers l'extérieur**. Les deux seuls services actifs sont `cupsd` (port `631`, qui gère l'impression) et `systemd-resolved` (port `53`, qui gère la résolution DNS), mais ils écoutent uniquement sur l'adresse locale `127.0.0.1`, donc ils ne sont pas accessibles depuis le réseau. J'ai également vérifié que le pare-feu **UFW** était bien activé et configuré pour bloquer par défaut toutes les connexions entrantes (`deny incoming`).

Avec l'option 4 (*Qui a frappé à la porte ?*), j'ai consulté les journaux d'authentification (`auth.log` et `journalctl`) pour vérifier si quelqu'un avait tenté de s'introduire sur mon poste ou de forcer un accès SSH. **Aucune attaque ni tentative suspecte n'a été détectée.** Une alerte liée à la commande `sudo` apparaissait dans les logs, mais après vérification, elle correspondait simplement à une erreur de frappe de ma part en tapant mon mot de passe.

3. JEUDI : INSTALLATION ET SÉCURISATION DE LA BORNE WI-FI (OPTIONS 5, 6, 8 ET 9)

Pour la dernière partie, j'ai installé (option 5) puis démarré (option 6) la borne Wi-Fi virtuelle sous **OpenWrt 25.12.6**. Au départ, l'audit de sécurité de la borne affichait un score de **10 / 100 (en rouge)** car elle utilisait les réglages par défaut. Je me suis donc connectée à la borne en SSH (`ssh -p 2222 root@127.0.0.1`) pour la sécuriser entièrement en ligne de commande à l'aide de l'utilitaire `uci`.

Voici le détail des actions menées pour durcir la borne Wi-Fi :

- **Protection du compte administrateur :** Comme le compte `root` n'avait aucun mot de passe par défaut, j'ai défini un nouveau mot de passe robuste de plus de 12 caractères avec la commande `passwd` pour bloquer tout accès non autorisé.
- **Activation et chiffrement du Wi-Fi principal :** J'ai activé la carte Wi-Fi de la borne (`wireless.radio0`), nommé le réseau `MonBastionWiFi` et activé le chiffrement **WPA3/WPA2** (`sae-mixed`) avec une clé complexe pour empêcher l'interception des données.

- **Création d'un réseau invité totalement isolé :** J'ai configuré une interface réseau séparée (`guest`) sur la plage IP `192.168.3.1/24` avec son propre serveur DHCP et un réseau Wi-Fi `MonBastion-Invite`. En activant l'isolation des clients (`isolate='1'`) et des règles de pare-feu strictes, les invités ont accès à Internet (`WAN`) et aux requêtes DNS/DHCP, mais sont totalement bloqués s'ils essaient de communiquer entre eux ou d'accéder au réseau local (`LAN`).
- **Sécurisation Web (HTTPS) et SSH (clés cryptographiques) :** J'ai forcé la redirection automatique de l'interface d'administration vers le **HTTPS** (`uhttpd.main.redirect_https='1'`). Pour le SSH, j'ai généré une paire de clés cryptographiques **Ed25519** sur mon PC, copié ma clé publique dans `/etc/dropbear/authorized_keys` , puis désactivé la connexion par mot de passe (`PasswordAuth='off'` et `RootPasswordAuth='off'`).
- **Sauvegarde et bilan final :** J'ai sauvegardé ma configuration avec l'option 9 dans l'archive locale `sauvegardes/borne-20261112-1133.tar.gz` (gardée uniquement sur mon PC pour ne pas exposer les mots de passe sur Git). Enfin, en relançant le bilan avec l'option 8, tous les tests sont passés au vert avec un **score final de 100 / 100** et les rapports ont été générés dans le dossier `rapports/` .